

# Vulnerability Assessment Report

OpenVAS / GVM Network Security Scan

|                 |                            |
|-----------------|----------------------------|
| Target IP       | 10.0.2.4 (127.0.0.1)       |
| Scan Date       | September 14, 2026         |
| Scanner Version | OpenVAS 22.7               |
| Report ID       | eaf3588e-15d9-44ba-b31c... |

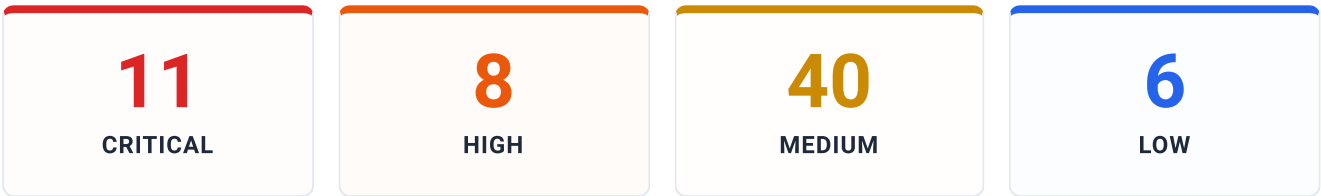
# Executive Summary

This report details the findings of a comprehensive vulnerability assessment performed using the OpenVAS/GVM scanning framework against the target infrastructure. The scan was executed using the "Full and Fast" system discovery profile with a minimum Quality of Detection (QoD) threshold of 70% to ensure high-fidelity results and minimize false positives.

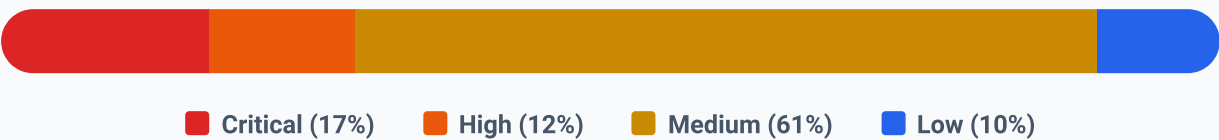
The assessment revealed a significantly exposed attack surface, characterized by obsolete operating systems, unencrypted legacy protocols, and multiple software components containing publicly known remote code execution (RCE) vulnerabilities. Immediate remediation is required to secure the environment.

## Vulnerability Distribution

The scanner identified a total of **65 verified vulnerabilities** (filtered from 490 total observations). The following metrics represent the risk distribution based on CVSS scoring methodology.



### Severity Breakdown (Proportional Density)



### Host Information & Exposure Profile

**Detected OS:** Linux Kernel 2.6.x (Ubuntu 8.04 LTS)  
**OS Status:** End of Life (EOL) Detected (CVSS 10.0)  
**Open TCP Ports:** 21, 22, 23, 25, 53, 80, 111, 139, 445, 512, 513, 514, 1099, 1524, 2049, 2121, 3306, 3632, 5432, 5900, 6200, 6697, 8009, 8787.

## Priority Action Matrix (Top Critical Risks)

The table below highlights the most severe vulnerabilities discovered during the assessment. These issues pose an immediate risk of system compromise (Remote Code Execution, Root Shell Access, or Authentication Bypass) and require urgent remediation.

| CVSS | Port     | Vulnerability Name                             | Category / Protocol    |
|------|----------|------------------------------------------------|------------------------|
| 10.0 | 8787/tcp | Distributed Ruby (dRuby/DRb) Multiple RCE      | Gain a shell remotely  |
| 10.0 | 80/tcp   | TWiki < 4.2.4 Multiple XSS / Command Execution | Web application abuses |
| 10.0 | 1524/tcp | Possible Backdoor: Ingreslock                  | Gain a shell remotely  |
| 10.0 | 513/tcp  | rlogin Passwordless Login                      | Gain a shell remotely  |
| 10.0 | N/A      | Operating System (OS) End of Life (EOL)        | General / System       |
| 9.8  | 6200/tcp | vsftpd Compromised Source Packages Backdoor    | FTP Backdoor           |
| 9.8  | 8009/tcp | Apache Tomcat AJP RCE (Ghostcat)               | Web Servers (AJP)      |
| 9.3  | 3632/tcp | DistCC RCE Vulnerability (CVE-2004-2687)       | Gain a shell remotely  |
| 9.0  | 5900/tcp | VNC Brute Force Login                          | Brute force attacks    |
| 9.0  | 5432/tcp | PostgreSQL Default Credentials                 | Default Accounts       |



### Executive Warning

The presence of multiple unauthenticated Remote Code Execution (RCE) vectors and active backdoors (Ingreslock, vsftpd) indicates that this system is trivially exploitable. If this host is exposed to any untrusted network, it must be considered actively compromised.

## Technical Details: Critical Findings

### Distributed Ruby (dRuby/DRb) Multiple RCE

CVSS: 10.0

**PORT / PROTOCOL**

8787 / tcp

**VULNERABILITY FAMILY**

Gain a shell remotely

**QUALITY OF DETECTION**

99% (Confirmed)

**Description:** Systems using Distributed Ruby (dRuby/DRb) may permit unauthorized systems to execute distributed commands. By default, Distributed Ruby does not impose restrictions on allowed hosts or set the \$SAFE environment variable to prevent privileged activities.

**Potential Impact:** An attacker could execute arbitrary system commands or Ruby scripts on the Distributed Ruby server. An attacker needs only the URI of the listening server to submit arbitrary Ruby commands resulting in total system compromise.

**Mitigation:** Ensure appropriate controls are in place. Implement taint on untrusted input, set \$SAFE levels appropriately ( $\geq 2$ ), and include drb/acl.rb to set ACLEntry restrictions to trusted hosts only.

### TWiki < 4.2.4 Multiple XSS / Command Execution

CVSS: 10.0

**PORT / PROTOCOL**

80 / tcp (HTTP)

**CVE REFERENCE**

CVE-2008-5304, 5305

**QUALITY OF DETECTION**

80%

**Description:** TWiki is prone to multiple cross-site scripting (XSS) and command execution vulnerabilities. The %SEARCH% variable is not properly sanitised before being used in an eval() call, which lets attackers execute perl code through eval injection.

**Potential Impact:** Successful exploitation allows execution of arbitrary script code or system commands under the context of the web server, allowing an attacker to compromise the application and steal credentials.

**Mitigation (Vendor Fix):** Update TWiki software to version 4.2.4 or later immediately.

## Technical Details: Critical Findings (Cont.)

### vsftpd Compromised Source Packages Backdoor

CVSS: 9.8

**PORT / PROTOCOL**  
21 / tcp & 6200 / tcp

**CVE REFERENCE**  
CVE-2011-2523

**QUALITY OF DETECTION**  
99% (Active Check)

**Description:** The FTP daemon (vsftpd 2.3.4) installed on the target contains a known backdoor. The tainted source package (downloaded between 2011-06-30 and 2011-07-03) contains malicious code that opens a command shell on port 6200/tcp when a specific payload is sent during FTP authentication.

**Potential Impact:** Remote attackers can exploit this issue to execute arbitrary shell commands in the context of the application (often root), leading to a complete compromise of the affected system.

**Mitigation:** Download the repaired package from the official vendor homepage and validate the package with its cryptographic signature, or replace the service with a secure file transfer alternative (SFTP).

### Apache Tomcat AJP RCE Vulnerability (Ghostcat)

CVSS: 9.8

**PORT / PROTOCOL**  
8009 / tcp (AJP)

**CVE REFERENCE**  
CVE-2020-1938

**QUALITY OF DETECTION**  
99% (Active Check)

**Description:** Apache Tomcat is prone to a remote code execution (RCE) vulnerability in the AJP connector, dubbed 'Ghostcat'. The server has a flaw allowing an attacker to read or include any files in all webapp directories on Tomcat, such as configuration files or source code.

**Potential Impact:** Allows unauthenticated remote attackers to read sensitive configuration files (e.g., WEB-INF/web.xml) or execute arbitrary code if the application allows file uploads.

**Mitigation:** Update Apache Tomcat to version 7.0.100, 8.5.51, 9.0.31 or later. Ensure the AJP connector is bound to localhost or disabled if not actively required for reverse-proxy communication.

# Strategic Remediation Roadmap

---

The assessment indicates that the target machine represents a "worst-case scenario" characterized by severely outdated software, active backdoors, and legacy cleartext protocols. The following strategic actions are recommended to secure the environment:

## 1. System Decommissioning & OS Upgrade

The underlying operating system (Ubuntu 8.04 LTS) reached End of Life (EOL) nearly a decade ago. It no longer receives security patches. The system must be decommissioned, and its services migrated to a supported, modern operating system (e.g., Ubuntu 22.04 LTS or 24.04 LTS).

## 2. Eradication of Legacy & Insecure Protocols

The scan identified multiple plaintext protocols and obsolete cryptographic standards being used actively:

- **Telnet (Port 23) & FTP (Port 21):** Disable immediately. Replace with SSH (Port 22) and SFTP.
- **rlogin/rsh (Ports 513, 514):** Disable these unencrypted remote shell utilities. Use SSH exclusively.
- **SSLv2 / SSLv3 / TLS 1.0:** Disable legacy encryption protocols prone to POODLE, DROWN, and BEAST attacks. Enforce TLS 1.2 or TLS 1.3.

## 3. Attack Surface Reduction (Port Closures)

Databases, compiler daemons, and internal services should never be exposed directly to network interfaces.

- Restrict database access (PostgreSQL on 5432, MySQL on 3306) to localhost or specific trusted application IP addresses using local firewalls (UFW/iptables).
- Disable development daemons (DistCC on 3632, dRuby on 8787) in production environments.
- Investigate and kill backdoor listener processes immediately (e.g., Ingreslock on 1524, vsftpd shell on 6200).

# Conclusion

---

The Metasploitable 2 target environment served as a highly effective laboratory for vulnerability analysis. The OpenVAS scan successfully enumerated over 60 vulnerabilities ranging from default credentials to critical remote code execution flaws and backdoors. Because this is an intentionally vulnerable machine, patching individual services is less relevant than understanding the attack vectors. In a real-world scenario, a system with this risk profile would be immediately quarantined from the network to prevent lateral movement.